Universidad Peruana Unión · Facultad de Ingeniería y Arquitectura
EP Ingeniería de Sistemas · Lenguaje de Programación II

Guía Práctica – Sesión 10
Seguridad backend: usuarios, BCrypt, JWT, roles y permisos

Estudiante: Tineo

Docente: Reyna Barreto Benjamin David

Ciclo: IV · Semestre 2026-2 · 15 de octubre de 2026

Repositorio: github.com/Legends600/TareaS1 · rama feature/seguridad-jwt

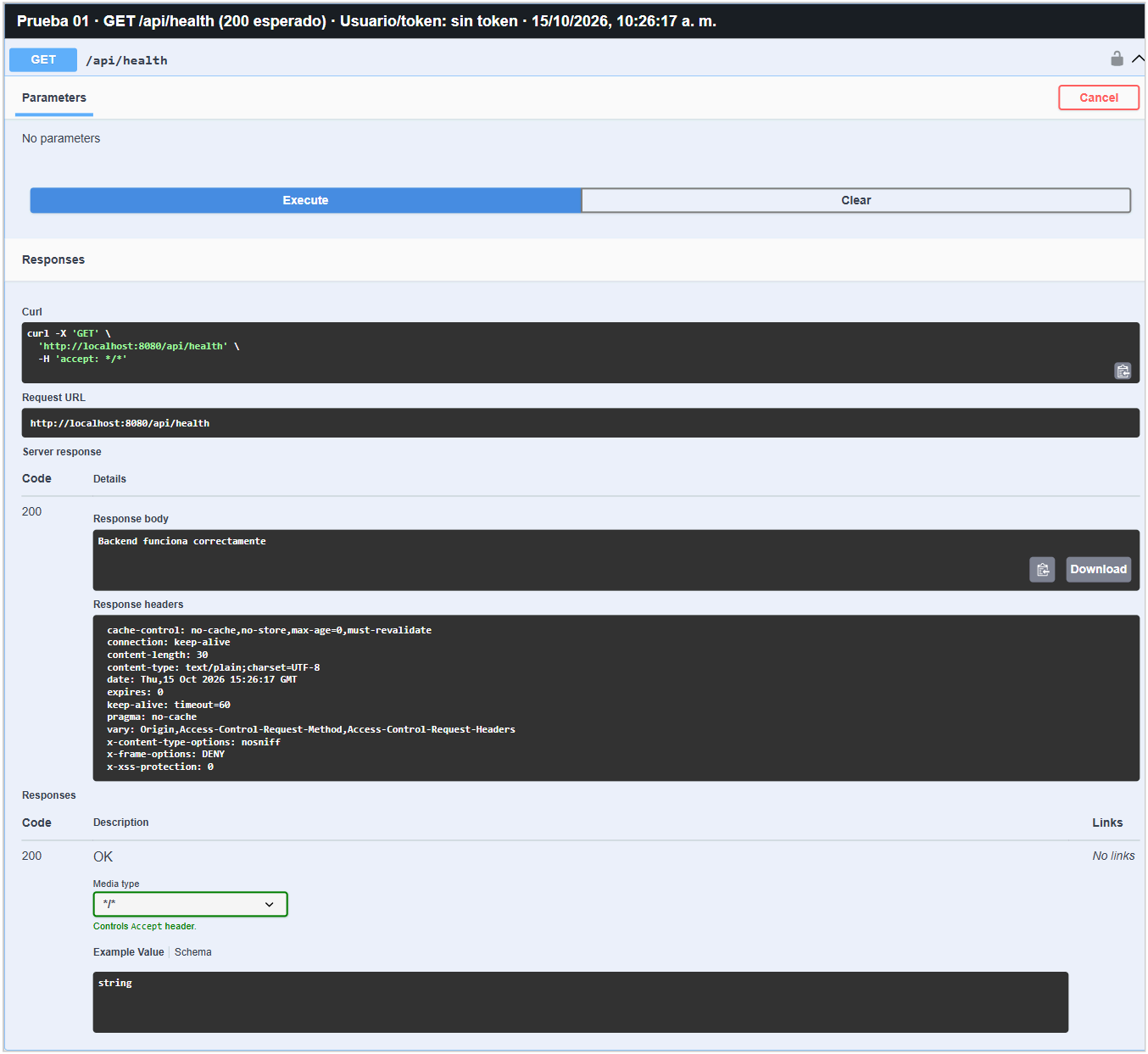
Resumen de las pruebas del paso 14

Las pruebas se ejecutaron desde Swagger UI (botón Authorize con el token del login) contra la API en http://localhost:8080 y Oracle. La prueba 24 se ejecutó en una segunda instancia (puerto 8081) con `app.jwt.expiracion-minutos=1`; la configuración del proyecto se mantiene en 60. La prueba 22 se ejecutó antes de la 20: con María aún sin usuario, el servicio llega a validar los roles (404); después del alta, la regla 1 a 1 responde 409 primero. Pruebas unitarias JwtServiceTest y PermisosPorRolTest: 9 de 9 en verde.

N.º	Usuario / token	Petición	Resultado esperado	Obtenido	Estado
01	Sin token	GET /api/health	200: ruta pública	200	**Pasa**
02	Sin token	GET /api/v1/productos	401 «Debe iniciar sesión para acceder a este recurso»	401	**Pasa**
03	—	Login admin con contraseña incorrecta	401 «Usuario o contraseña incorrectos»	401	**Pasa**
04	—	Login inactivo / Inactivo2026*	401 con el mismo mensaje	401	**Pasa**
05	—	Login con username vacío	400 con validationErrors.username	400	**Pasa**
06	—	Login vendedor / Vendedor2026*	200 con token, roles [VENDEDOR] y permisos	200	**Pasa**
07	vendedor	Decodificar la parte central del token (atob)	sub, authorities, iat y exp; exp − iat = 3600	exp − iat = 3600	**Pasa**
08	vendedor	GET /api/v1/auth/me	200 con el usuario, sin contraseña	200	**Pasa**
09	vendedor	GET /api/v1/productos	200	200	**Pasa**
10	vendedor	DELETE /api/v1/productos/1	403 «No tiene permisos para realizar esta operación»	403	**Pasa**
11	vendedor	POST /api/v1/ventas	201	201	**Pasa**
12	vendedor	GET /api/v1/reportes/ventas-por-categoria	403 (@PreAuthorize)	403	**Pasa**
13	almacen	POST /api/v1/ventas	403	403	**Pasa**
14	almacen	PUT /api/v1/productos/59	200	200	**Pasa**
15	admin	GET /api/v1/reportes/ventas-por-categoria	200	200	**Pasa**
16	—	Login supervisor / Supervisor2026*	200 con roles [ALMACENERO, VENDEDOR] y la unión de permisos	200	**Pasa**
17	supervisor	POST /api/v1/ventas y PUT /api/v1/productos/59	201 y 200	201 y 200	**Pasa**
18	supervisor	GET /api/v1/reportes/ventas-por-categoria	403	403	**Pasa**
19	admin	GET /api/v1/empleados y GET /api/v1/roles	200; María con tieneUsuario: false	200 y 200	**Pasa**
20	admin	POST /api/v1/usuarios para María	201 sin contraseña; hash $2a$10$ y fila en usuario_roles	201	**Pasa**
21	admin	Repetir alta con el mismo empleadoId	409 «El empleado … ya tiene un usuario»	409	**Pasa**
22	admin	Alta con rollds [2, 99]	404 «Roles no encontrados: [99]»	404	**Pasa**
23	vendedor	Token con un carácter cambiado	401 «El token no es válido»	401	**Pasa**
24	vendedor	Token con expiracion-minutos: 1, 2 minutos después	401 «El token ha expirado. Inicie sesión nuevamente»	401	**Pasa**

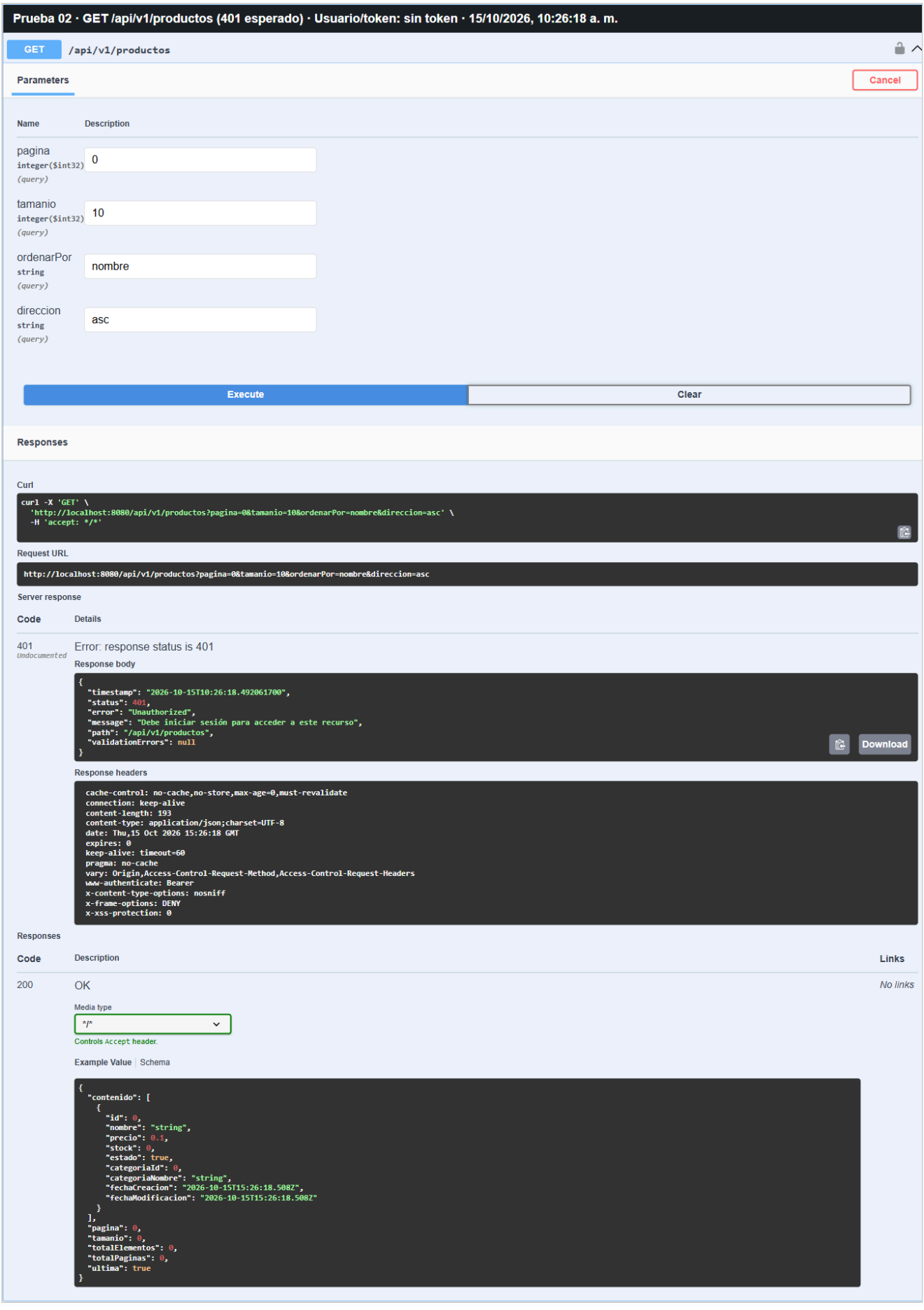
Prueba 01 · GET /api/health

Usuario / token: Sin token · **Esperado:** 200: ruta pública · **Obtenido:** 200



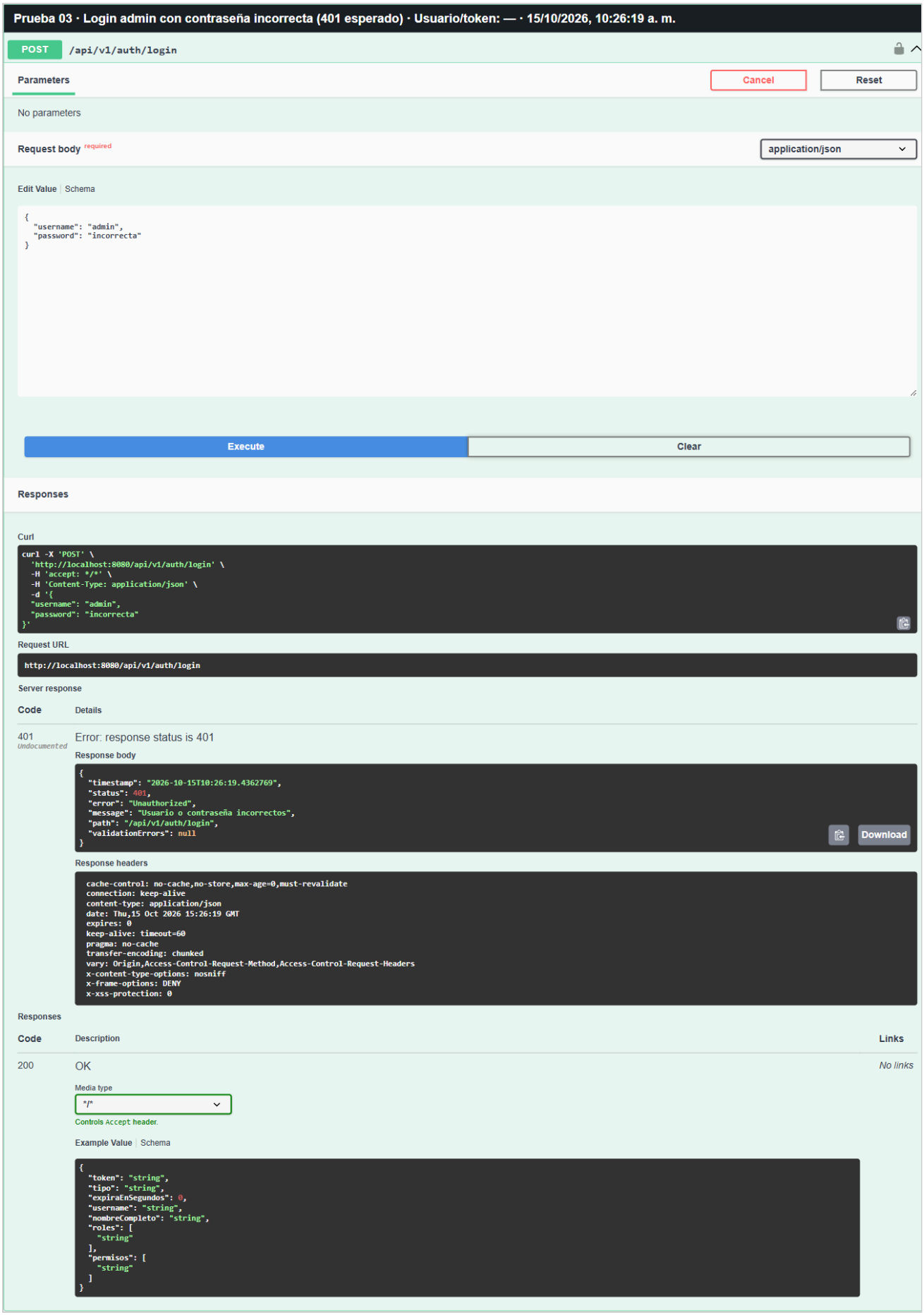
Prueba 02 · GET /api/v1/productos

Usuario / token: Sin token · **Esperado:** 401 «Debe iniciar sesión para acceder a este recurso» · **Obtenido:** 401



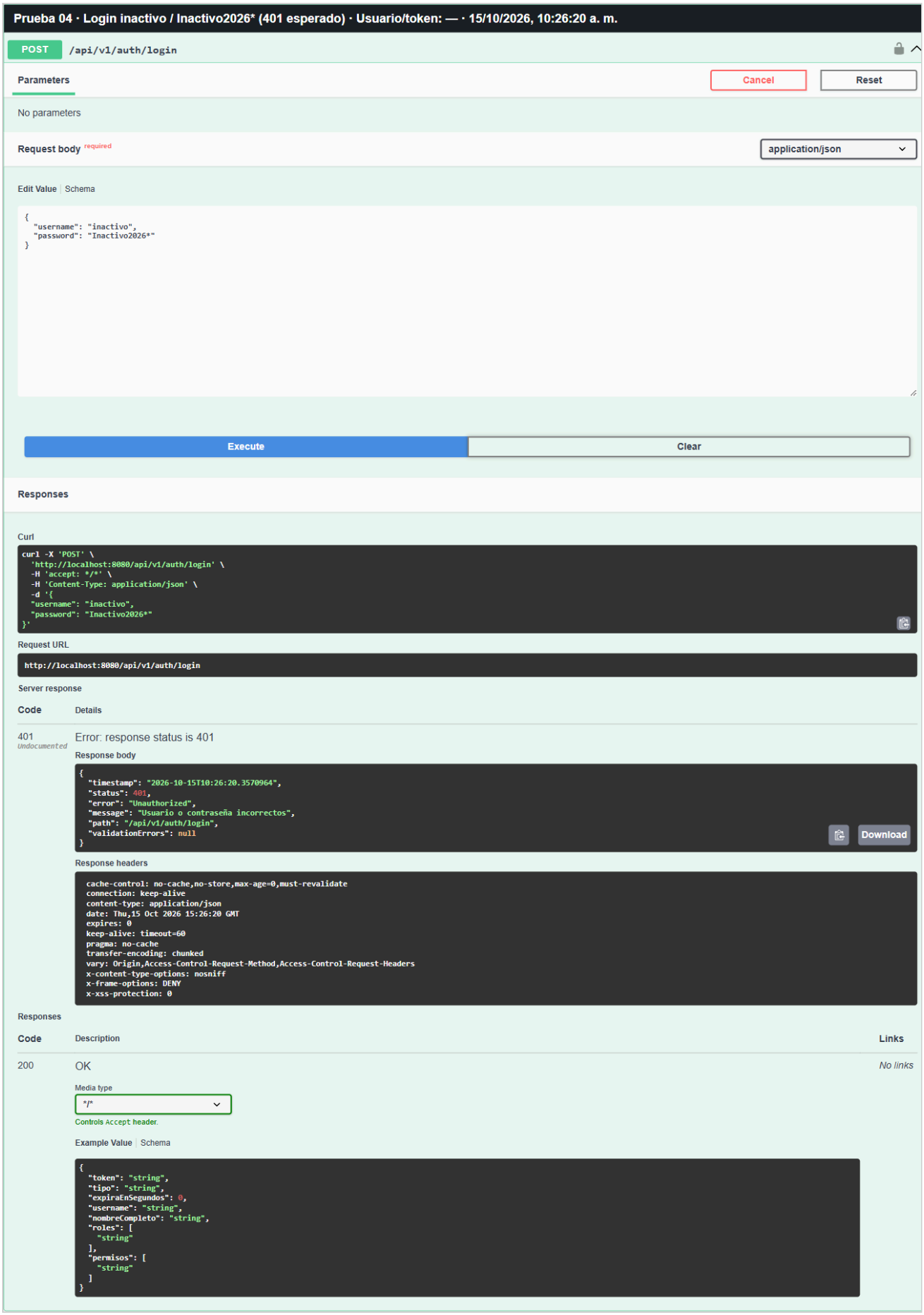
Prueba 03 · Login admin con contraseña incorrecta

Usuario / token: — · **Esperado:** 401 «Usuario o contraseña incorrectos» · **Obtenido:** 401



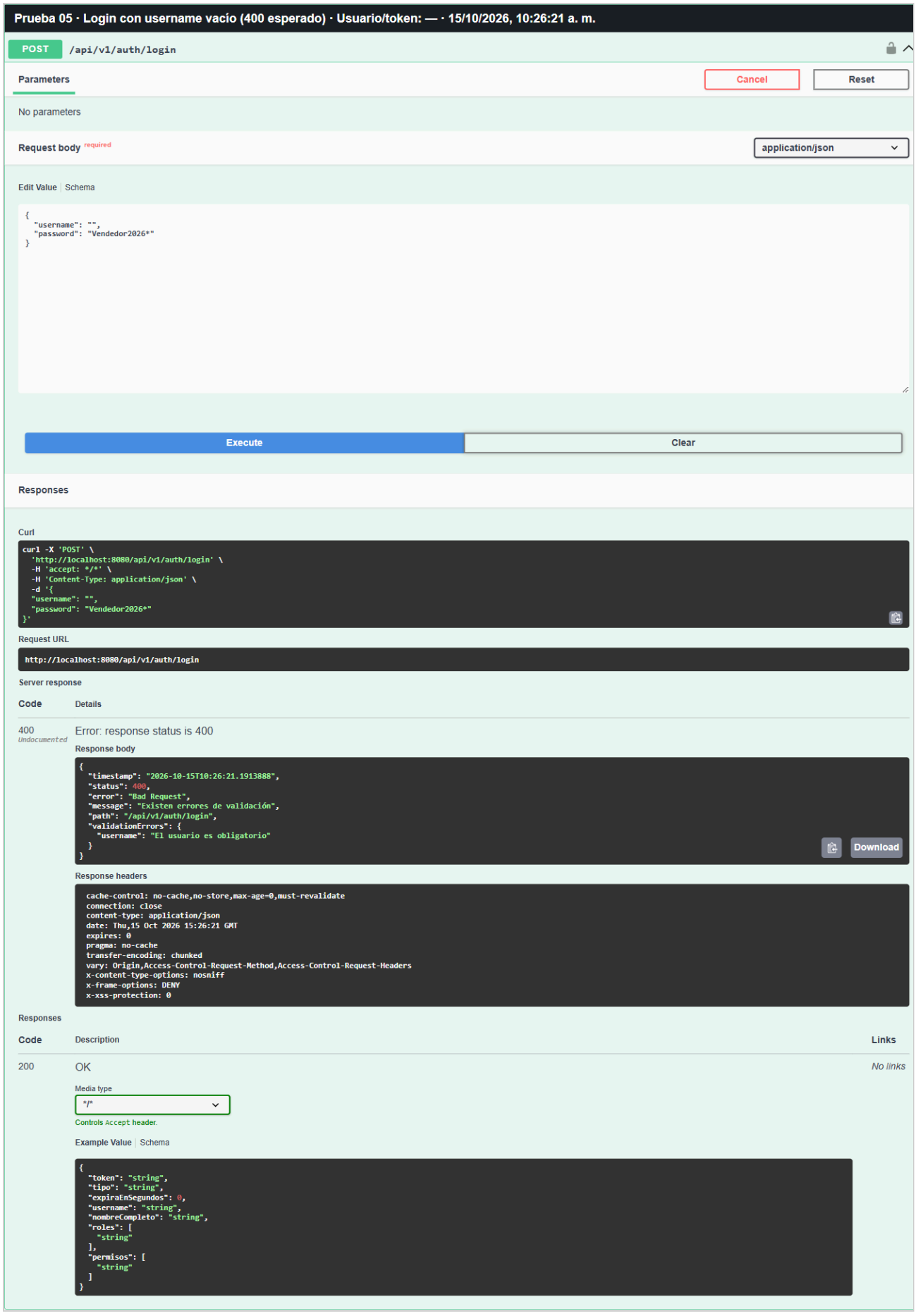
Prueba 04 · Login inactivo / Inactivo2026*

Usuario / token: — · **Esperado:** 401 con el mismo mensaje · **Obtenido:** 401



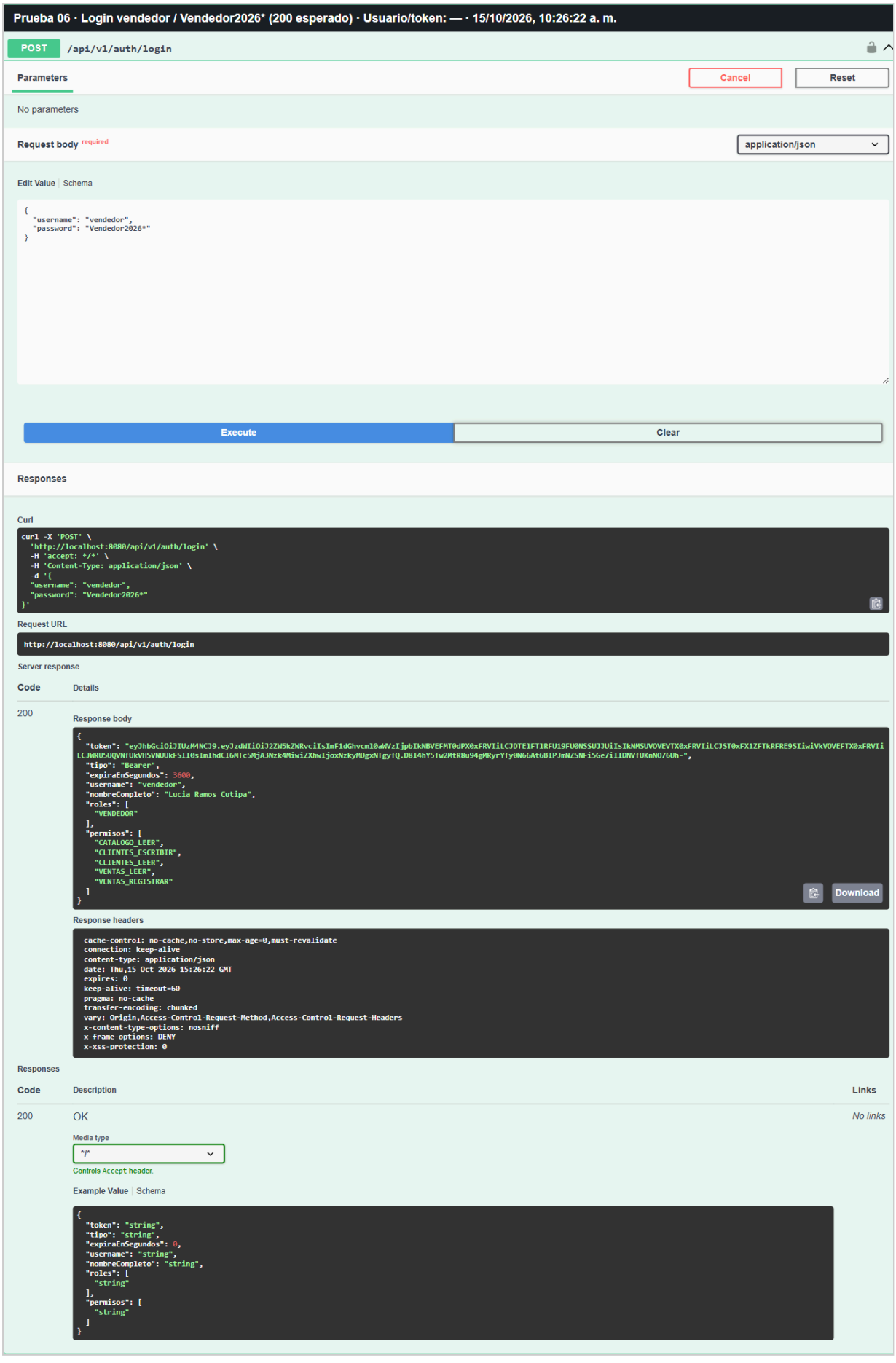
Prueba 05 · Login con username vacío

Usuario / token: — · **Esperado:** 400 con validationErrors.username · **Obtenido:** 400



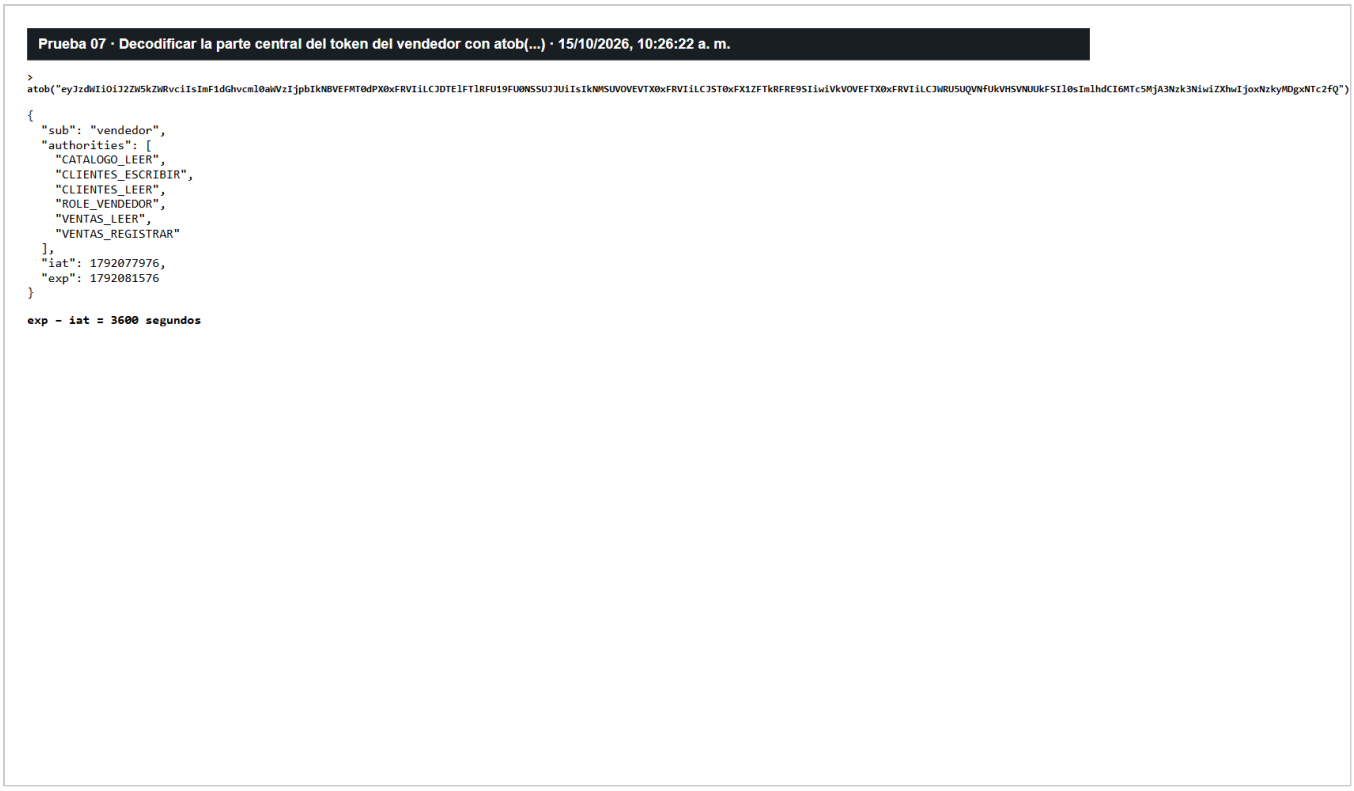
Prueba 06 · Login vendedor / Vendedor2026*

Usuario / token: — · **Esperado:** 200 con token, roles [VENDEDOR] y permisos · **Obtenido:** 200



Prueba 07 · Decodificar la parte central del token (atob)

Usuario / token: vendedor · **Esperado:** sub, authorities, iat y exp; exp − iat = 3600 · **Obtenido:** exp − iat = 3600



Prueba 07 · Decodificar la parte central del token del vendedor con atob(...) · 15/10/2026, 10:26:22 a. m.

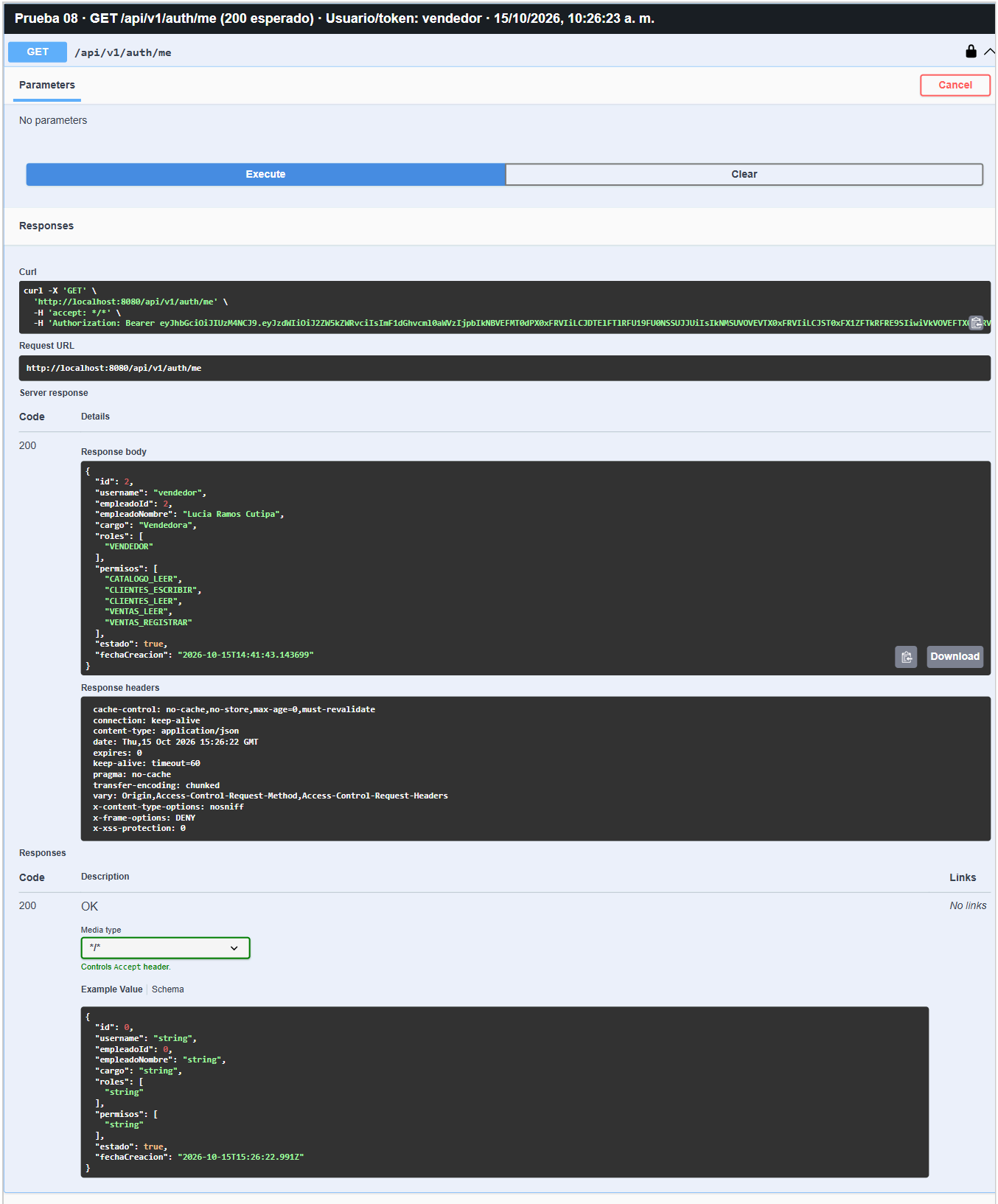
```
> atob("eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRU5UQVNfUkVHSVNUUkFSIl0sImlhdCI6MTc5MjA3Nzk3NiwiZXhwIjoxNzkyMDgxNTc2fQ")

{
  "sub": "vendedor",
  "authorities": [
    "CATALOGO_LEER",
    "CLIENTES_ESCRIBIR",
    "CLIENTES_LEER",
    "ROLE_VENDEDOR",
    "VENTAS_LEER",
    "VENTAS_REGISTRAR"
  ],
  "iat": 1792077976,
  "exp": 1792081576
}

exp - iat = 3600 segundos
```

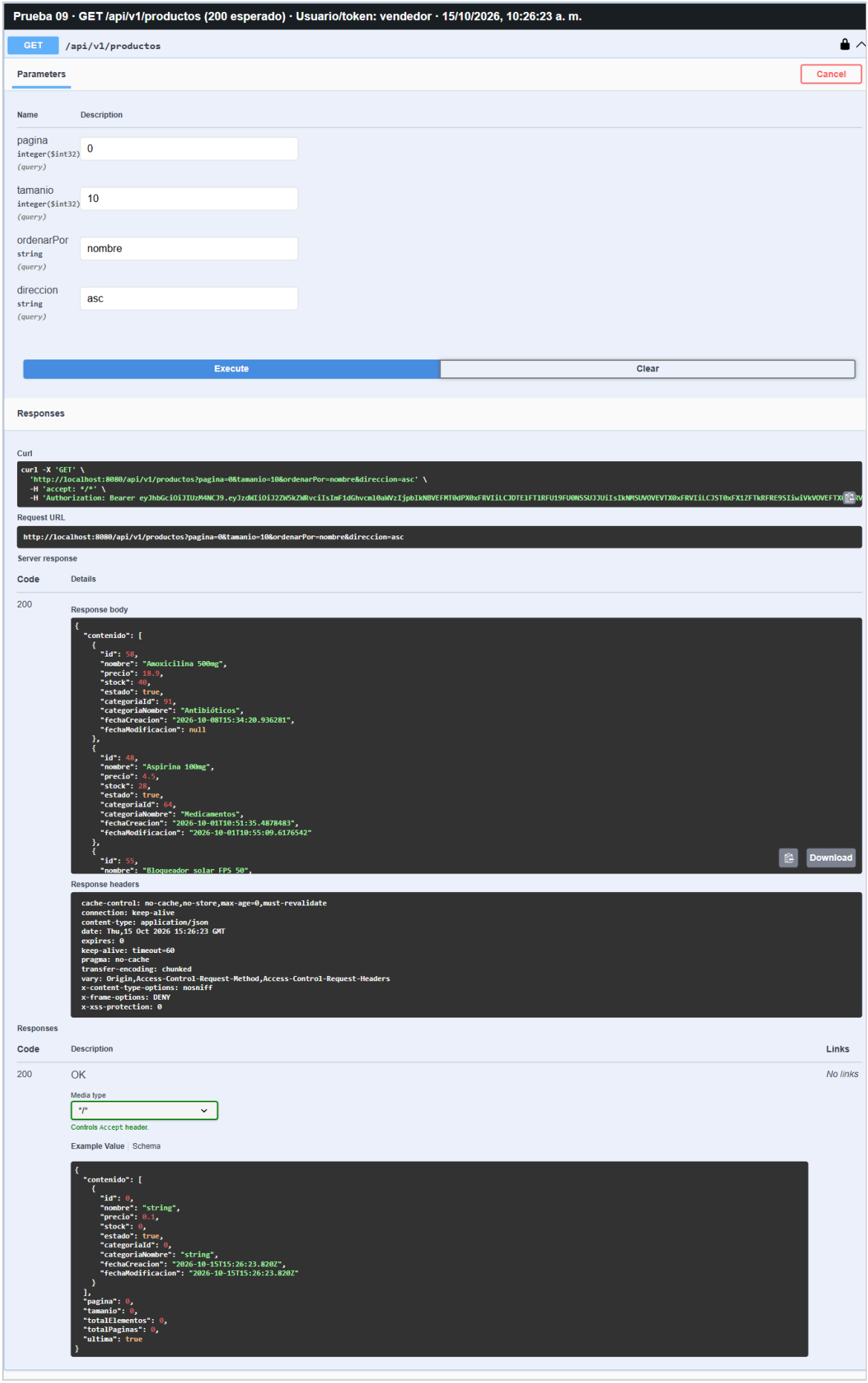
Prueba 08 · GET /api/v1/auth/me

Usuario / token: vendedor · **Esperado:** 200 con el usuario, sin contraseña · **Obtenido:** 200



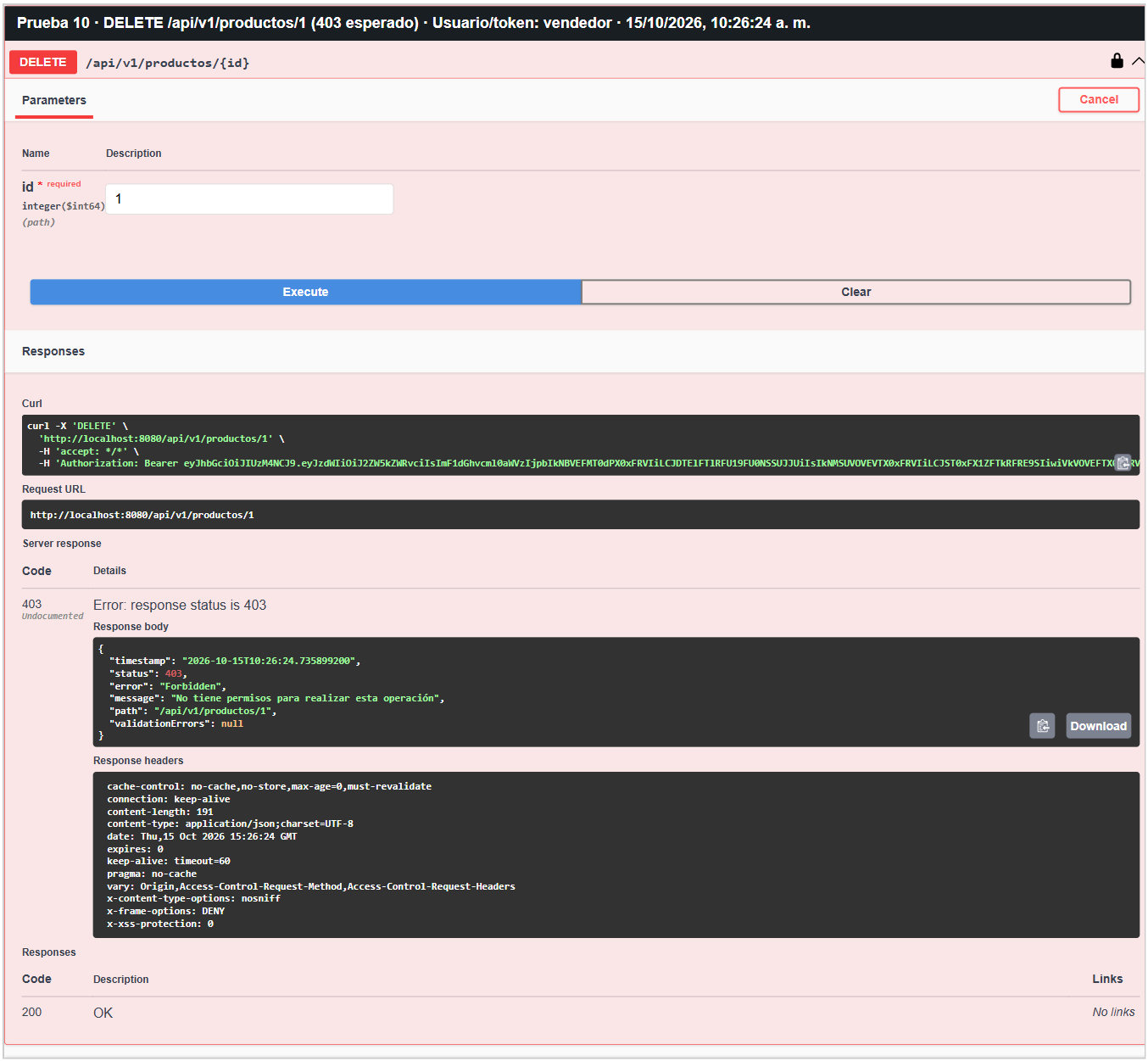
Prueba 09 · GET /api/v1/productos

Usuario / token: vendedor · **Esperado:** 200 · **Obtenido:** 200



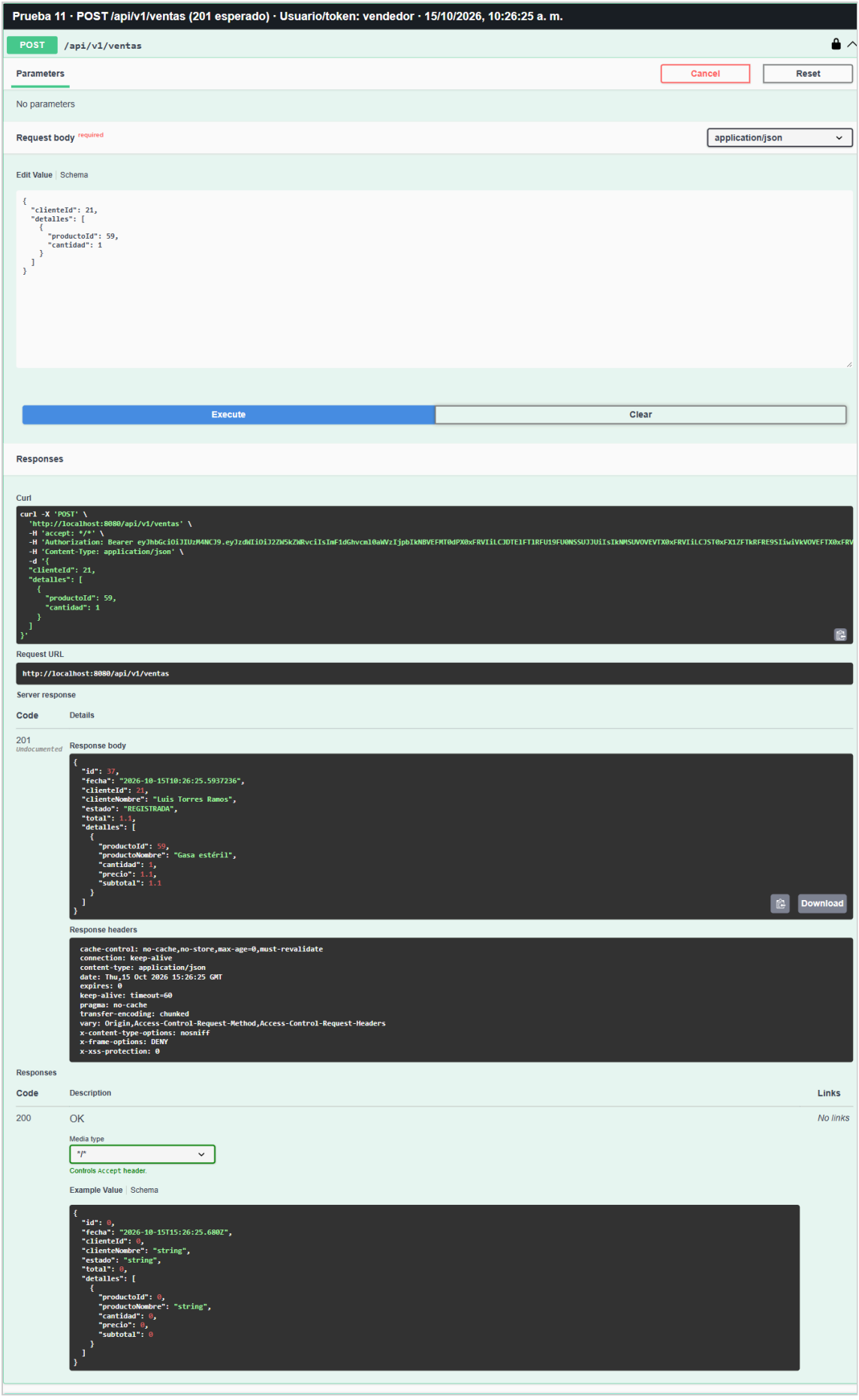
Prueba 10 · DELETE /api/v1/productos/1

Usuario / token: vendedor · **Esperado:** 403 «No tiene permisos para realizar esta operación» · **Obtenido:** 403



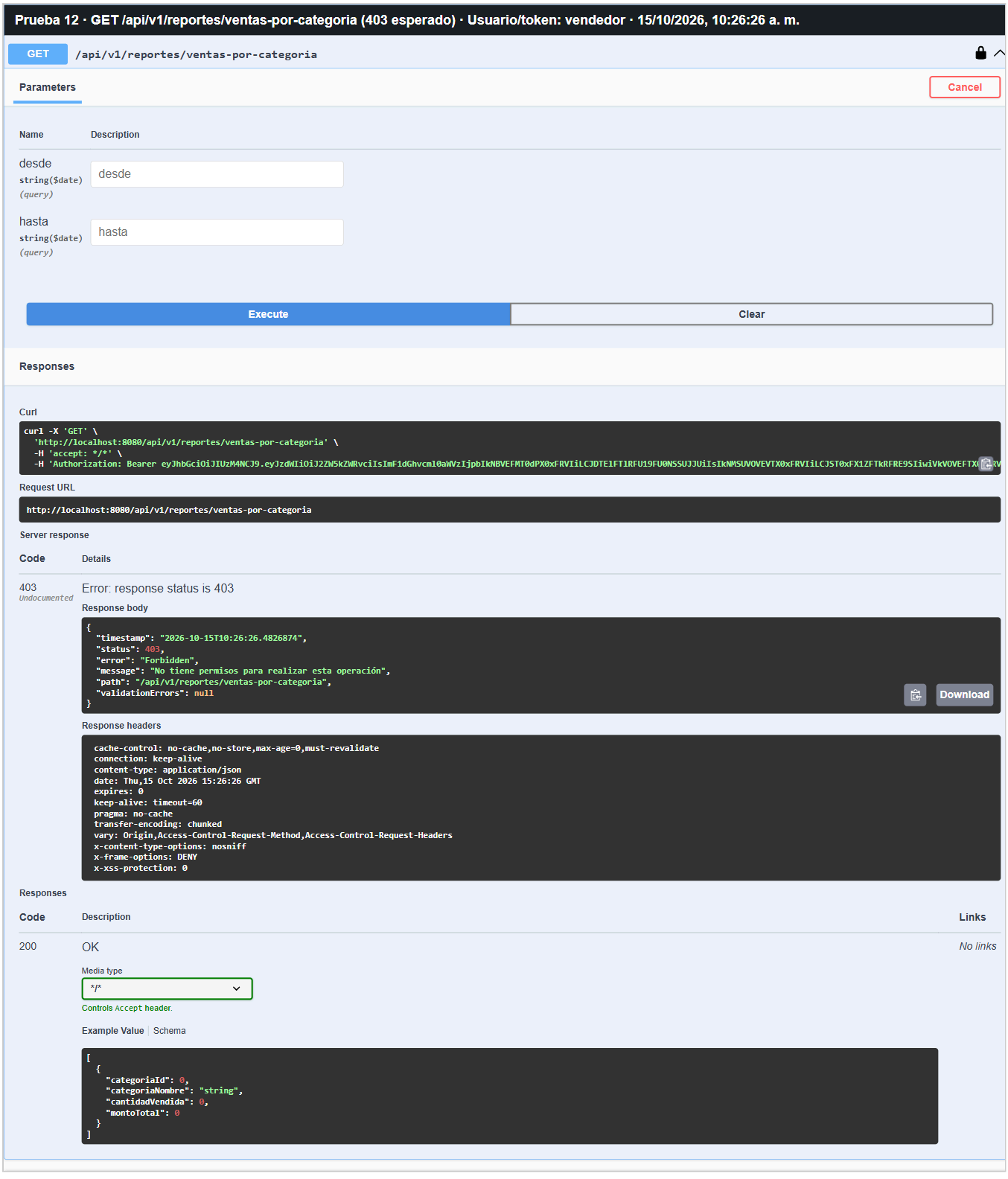
Prueba 11 · POST /api/v1/ventas

Usuario / token: vendedor · **Esperado:** 201 · **Obtenido:** 201



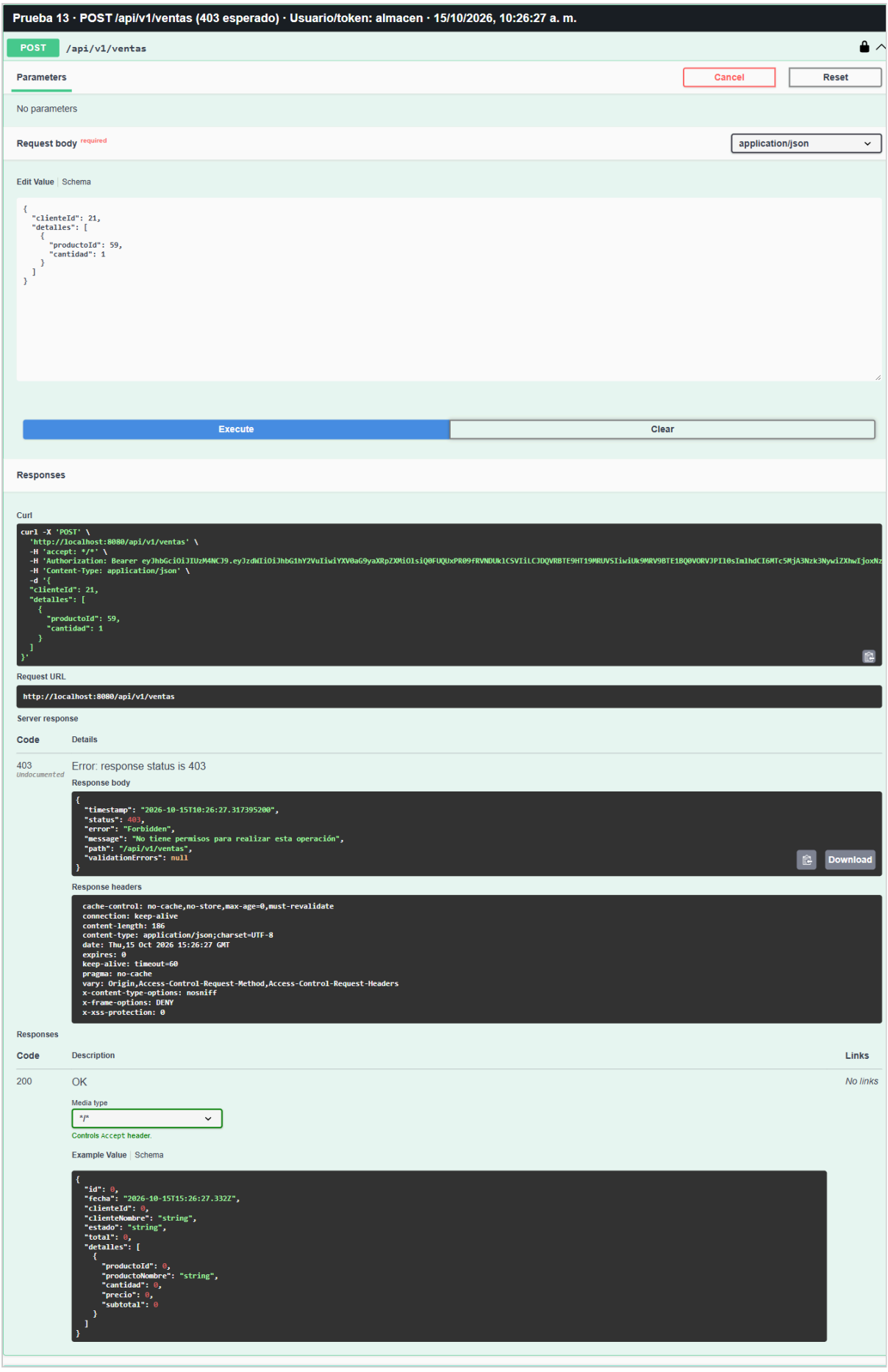
Prueba 12 · GET /api/v1/reportes/ventas-por-categoria

Usuario / token: vendedor · **Esperado:** 403 (@PreAuthorize) · **Obtenido:** 403



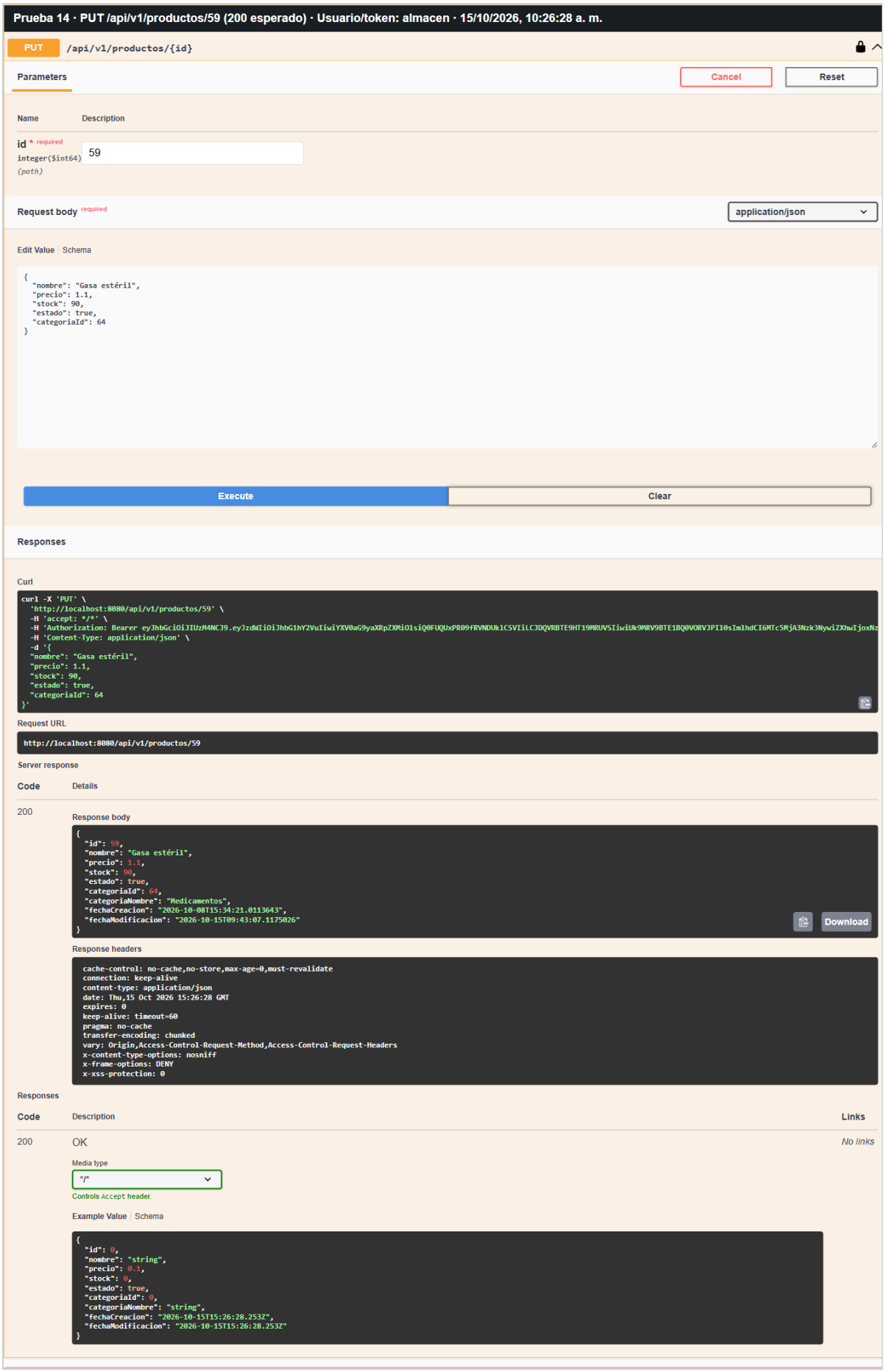
Prueba 13 · POST /api/v1/ventas

Usuario / token: almacen · **Esperado:** 403 · **Obtenido:** 403



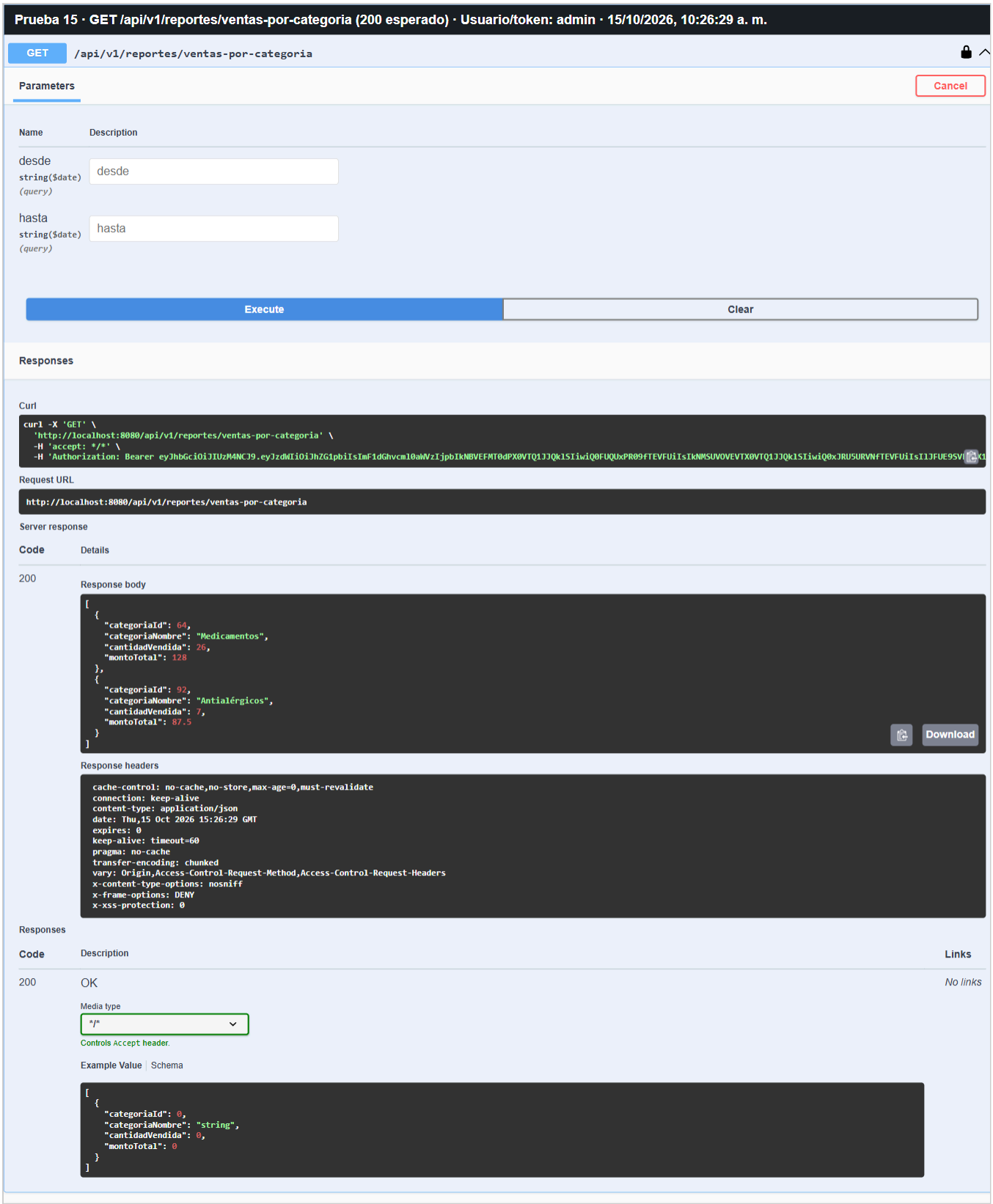
Prueba 14 · PUT /api/v1/productos/59

Usuario / token: almacen · **Esperado:** 200 · **Obtenido:** 200



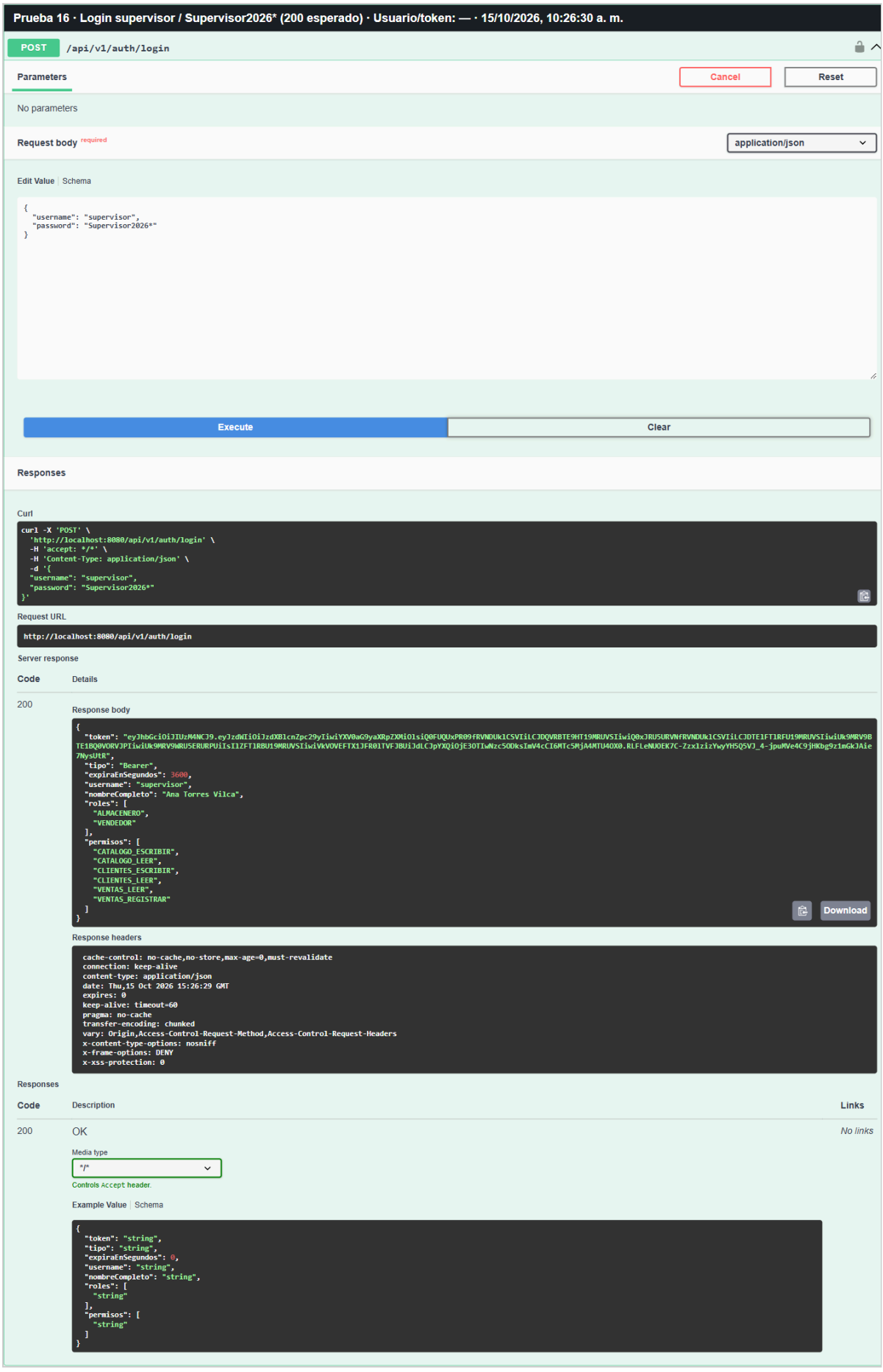
Prueba 15 · GET /api/v1/reportes/ventas-por-categoria

Usuario / token: admin · **Esperado:** 200 · **Obtenido:** 200



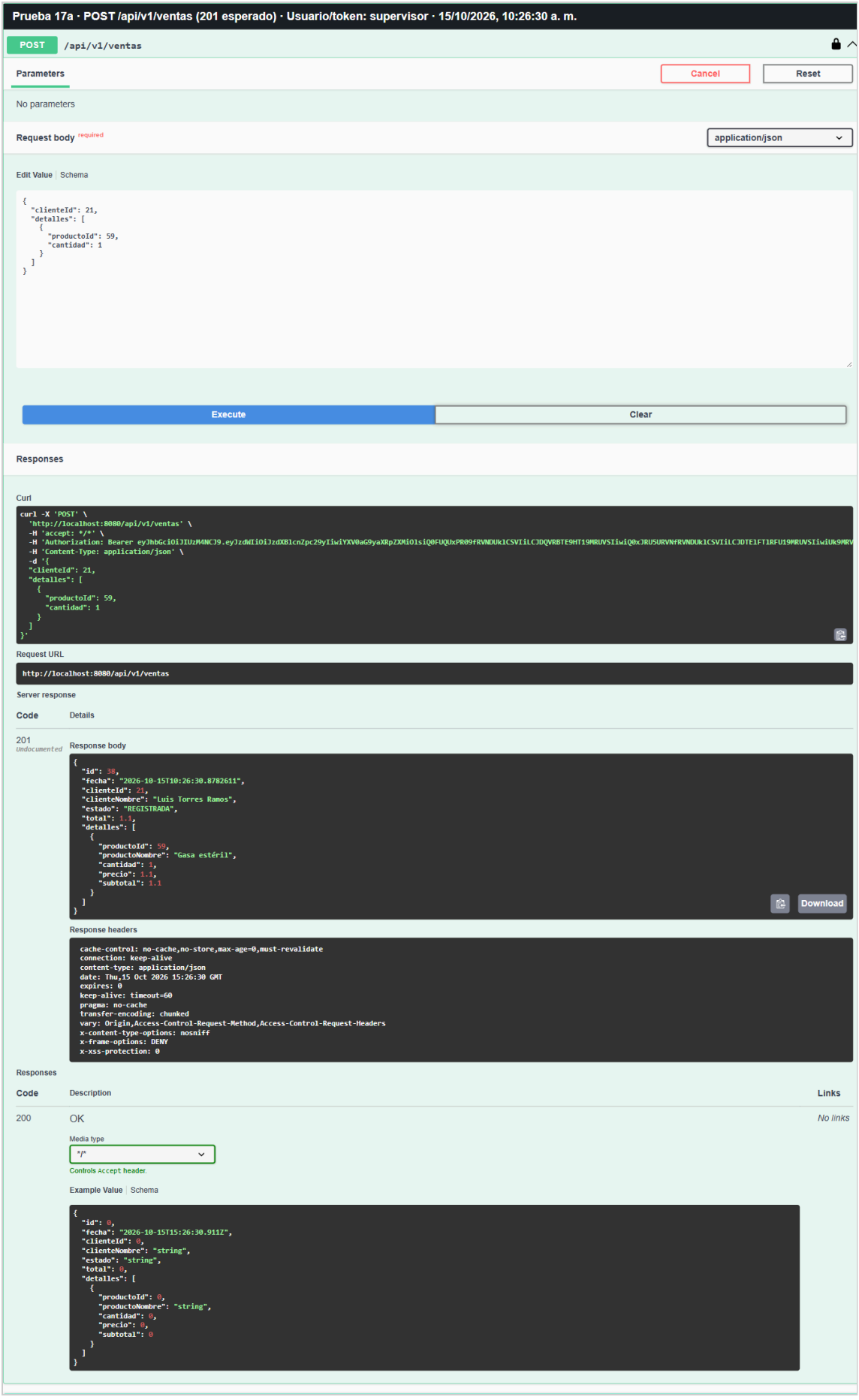
Prueba 16 · Login supervisor / Supervisor2026*

Usuario / token: — · **Esperado:** 200 con roles [ALMACENERO, VENDEDOR] y la unión de permisos · **Obtenido:** 200



Prueba 17 · POST /api/v1/ventas y PUT /api/v1/productos/59

Usuario / token: supervisor · **Esperado:** 201 y 200 · **Obtenido:** 201 y 200



Prueba 17b · PUT /api/v1/productos/59 (200 esperado) · Usuario/token: supervisor · 15/10/2026, 10:26:31 a. m.

PUT `/api/v1/productos/{id}`

Parameters — Cancel — Reset

Name	Description
id * required integer($int64) (path)	59

Request body required — application/json

Edit Value | Schema

```
{
  "nombre": "Gasa estéril",
  "precio": 1.1,
  "stock": 90,
  "estado": true,
  "categoriaId": 64
}
```

Execute — Clear

Responses

Curl

```
curl -X 'PUT' \
  'http://localhost:8080/api/v1/productos/59' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJzdXB1cnZpc29yIiwiYXV0aG9yaXRpZXMiOlsiQ0FUQUxPR09fRVNDUk1CSVIiLCJDQVRBTE9HT19MRUVSIiwiQ0xJRU5URVNfRVNDUk1CSVIiLCJDTE1FT1RfTEVU19MRUVSIiwiUk9MRV
  -H 'Content-Type: application/json' \
  -d '{
  "nombre": "Gasa estéril",
  "precio": 1.1,
  "stock": 90,
  "estado": true,
  "categoriaId": 64
}'
```

Request URL

```
http://localhost:8080/api/v1/productos/59
```

Server response

Code	Details
200	Response body

```
{
  "id": 59,
  "nombre": "Gasa estéril",
  "precio": 1.1,
  "stock": 90,
  "estado": true,
  "categoriaId": 64,
  "categoriaNombre": "Medicamentos",
  "fechaCreacion": "2026-10-08T15:34:21.0113643",
  "fechaModificacion": "2026-10-15T10:26:28.2204397"
}
```

Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Thu,15 Oct 2026 15:26:31 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

Code	Description	Links
200	OK	*No links*

Media type: */*

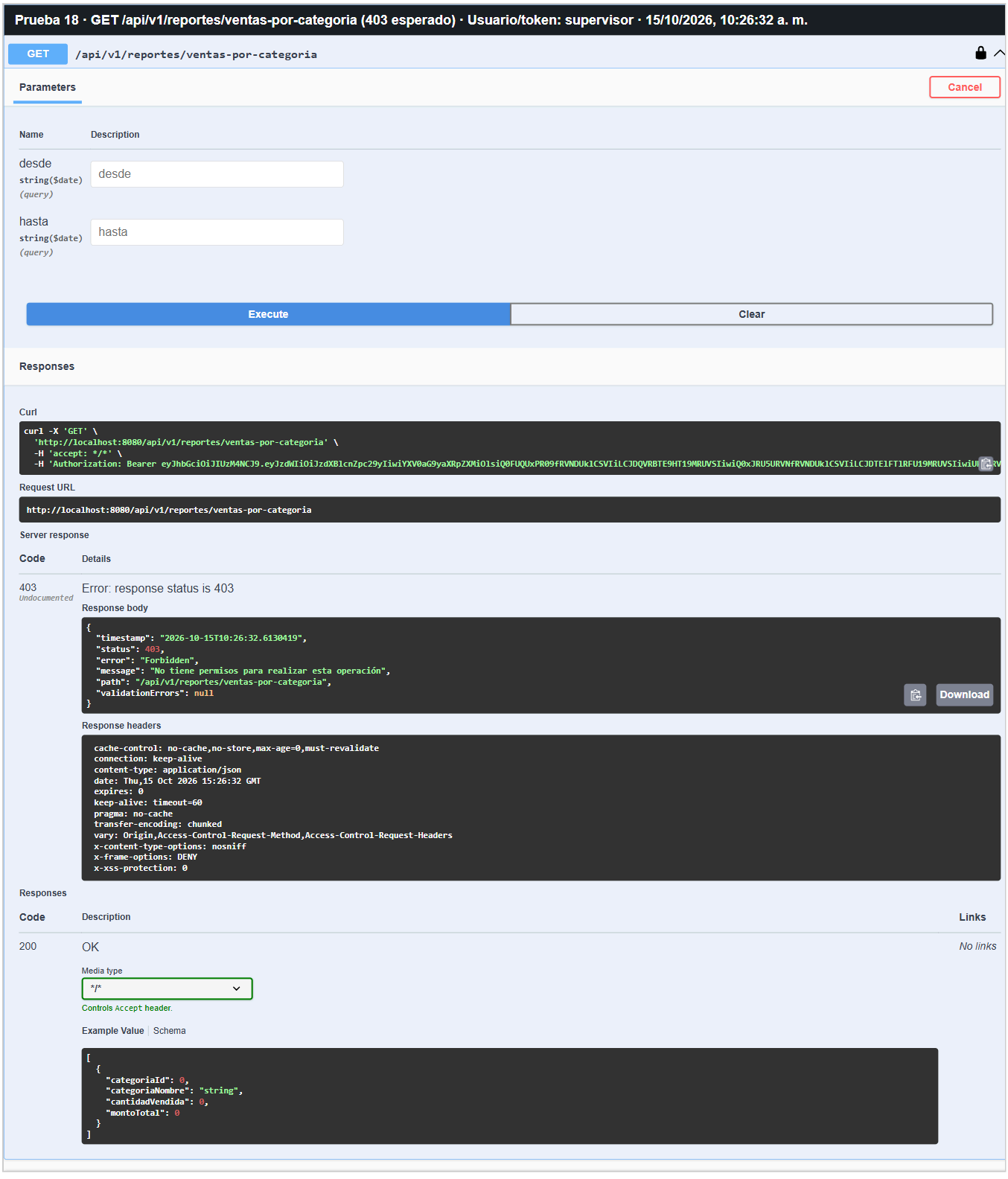
Controls Accept header.

Example Value | Schema

```
{
  "id": 0,
  "nombre": "string",
  "precio": 0.1,
  "stock": 0,
  "estado": true,
  "categoriaId": 0,
  "categoriaNombre": "string",
  "fechaCreacion": "2026-10-15T15:26:31.823Z",
  "fechaModificacion": "2026-10-15T15:26:31.823Z"
}
```

Prueba 18 · GET /api/v1/reportes/ventas-por-categoria

Usuario / token: supervisor · **Esperado:** 403 · **Obtenido:** 403



Prueba 19 · GET /api/v1/empleados y GET /api/v1/roles

Usuario / token: admin · **Esperado:** 200; María con tieneUsuario: false · **Obtenido:** 200 y 200

Prueba 19a · GET /api/v1/empleados (200 esperado; María sin usuario) · Usuario/token: admin · 15/10/2026, 10:26:33 a. m.

GET /api/v1/empleados

Parameters | Cancel

No parameters

Execute | Clear

Responses

Curl

```
curl -X 'GET' \
  'http://localhost:8080/api/v1/empleados' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JQklSIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JQklSIiwiQ0xJRU5URVNfTEVFUiIsIlJFUE9SVI
```

Request URL

```
http://localhost:8080/api/v1/empleados
```

Server response

Code | Details

200

Response body


```
[
  {
    "id": 5,
    "dni": "44556677",
    "nombres": "Jorge",
    "apellidos": "Apaza Huanca",
    "cargo": "Vendedor",
    "email": "japaza@pharmasoft.pe",
    "telefono": null,
    "estado": true,
    "tieneUsuario": true
  },
  {
    "id": 6,
    "dni": "45667788",
    "nombres": "Maria",
    "apellidos": "Huaman Torres",
    "cargo": "Cajera",
    "email": "mhuaman@pharmasoft.pe",
    "telefono": null,
    "estado": true,
    "tieneUsuario": false
  },
  {
    "id": 1,
    "dni": "40112233",
    "nombres": "Rosa Elena",
```


Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Thu,15 Oct 2026 15:26:33 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

Code	Description	Links
200	OK	*No links*

Media type

/

Controls Accept header.

Example Value | Schema


```
[
  {
    "id": 0,
    "dni": "string",
    "nombres": "string",
    "apellidos": "string",
    "cargo": "string",
    "email": "string",
    "telefono": "string",
    "estado": true,
    "tieneUsuario": true
  }
]
```

Prueba 19b · GET /api/v1/roles (200 esperado) · Usuario/token: admin · 15/10/2026, 10:26:34 a. m.

GET /api/v1/roles

Parameters | Cancel

No parameters

Execute | Clear

Responses

Curl

```
curl -X 'GET' \
  'http://localhost:8080/api/v1/roles' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQk1SIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQk1SIiwiQ0xJRUSURVNfTEVFUiIsI1JFUE9SVX1
```

Request URL

```
http://localhost:8080/api/v1/roles
```

Server response

Code	Details

200

Response body


```
[
  {
    "id": 1,
    "nombre": "ADMIN",
    "descripcion": "Administra usuarios, ve reportes y opera todo el sistema",
    "permisos": [
      "CATALOGO_ESCRIBIR",
      "CATALOGO_LEER",
      "CLIENTES_ESCRIBIR",
      "CLIENTES_LEER",
      "REPORTES_VER",
      "USUARIOS_ADMINISTRAR",
      "VENTAS_LEER",
      "VENTAS_REGISTRAR"
    ]
  },
  {
    "id": 3,
    "nombre": "ALMACENERO",
    "descripcion": "Mantiene categorias y productos",
    "permisos": [
      "CATALOGO_ESCRIBIR",
      "CATALOGO_LEER"
    ]
  },
  {
    "id": 2,
```


Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Thu,15 Oct 2026 15:26:34 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

Code	Description	Links
200	OK	*No links*

Media type

/

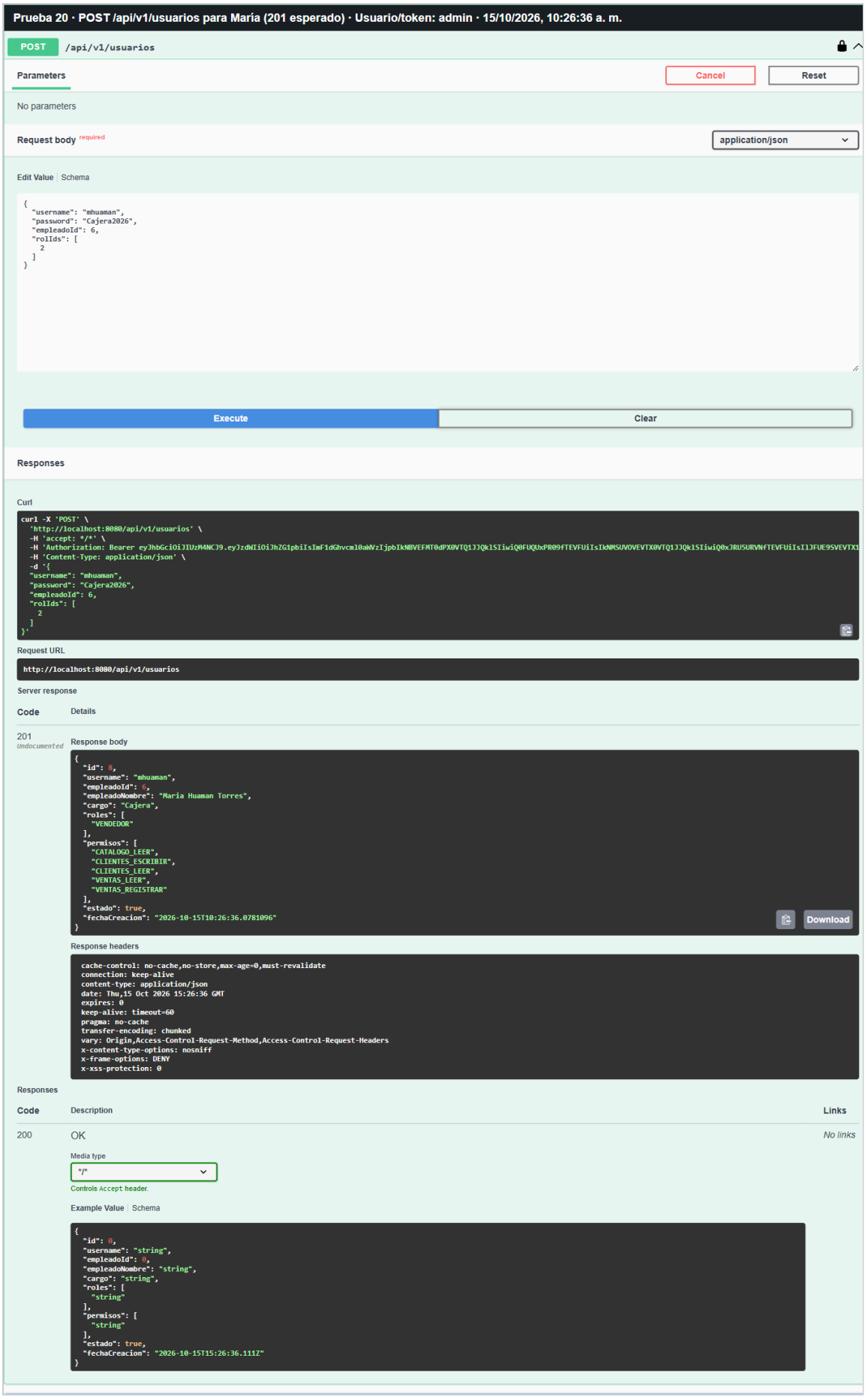
Controls Accept header.

Example Value | Schema


```
[
  {
    "id": 0,
    "nombre": "string",
    "descripcion": "string",
    "permisos": [
      "string"
    ]
  }
]
```

Prueba 20 · POST /api/v1/usuarios para María

Usuario / token: admin · **Esperado:** 201 sin contraseña; hash $2a$10$ y fila en usuario_roles · **Obtenido:** 201



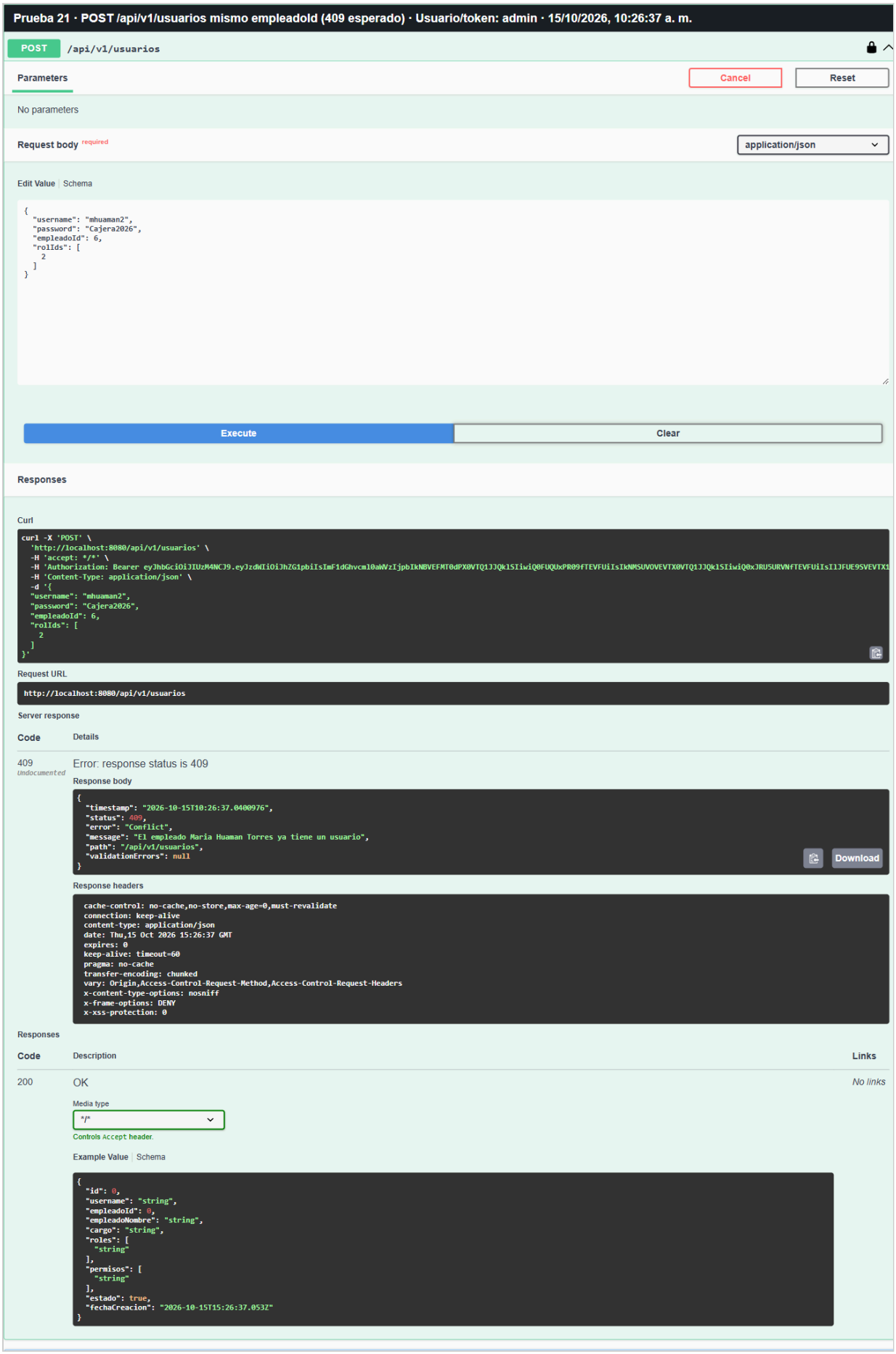
Prueba 20 · Verificación en Oracle: password de mhuaman es hash BCrypt ($2a$10$, 60 caracteres) y usuario_roles tiene la fila nueva · 15/10/2026, 10:27:35 a. m.

```
SQL> select u.username, u.password, length(u.password) largo, r.nombre rol
       from usuarios u join usuario_roles ur on ur.usuario_id = u.id
       join roles r on r.id = ur.rol_id where u.username = 'mhuaman';

USERNAME   PASSWORD                                                       LARGO
---------- ------------------------------------------------------------ ----------
ROL
--------------------------------------------------------------------------------------------------------------------------------
mhuaman    $2a$10$BnUPFyMauSL2DXchT4HRVednVQExZ/a5wJg.j2aab8rkDlMoiM7TC          60
VENDEDOR
```

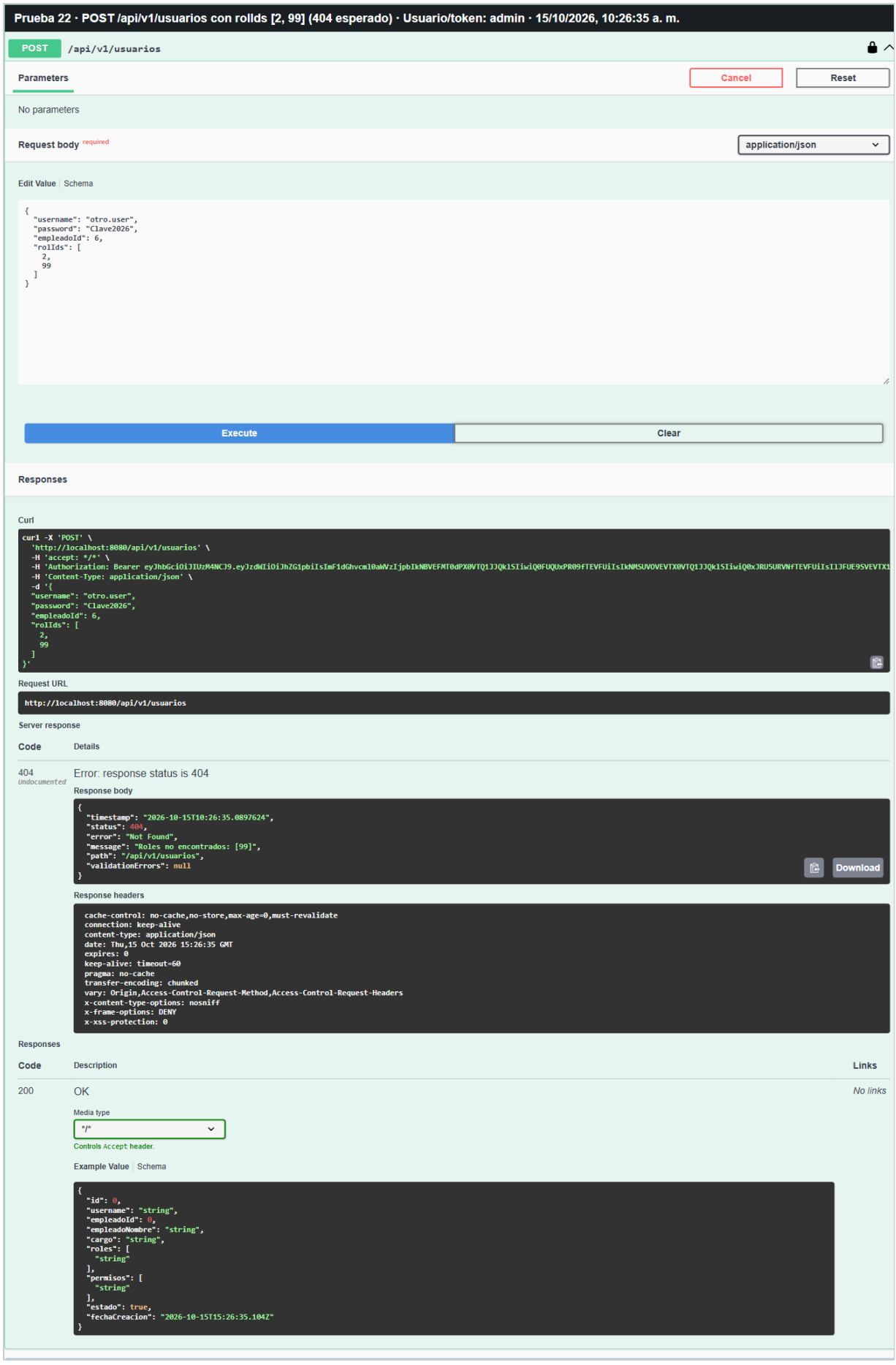
Prueba 21 · Repetir alta con el mismo empleadoId

Usuario / token: admin · **Esperado:** 409 «El empleado … ya tiene un usuario» · **Obtenido:** 409



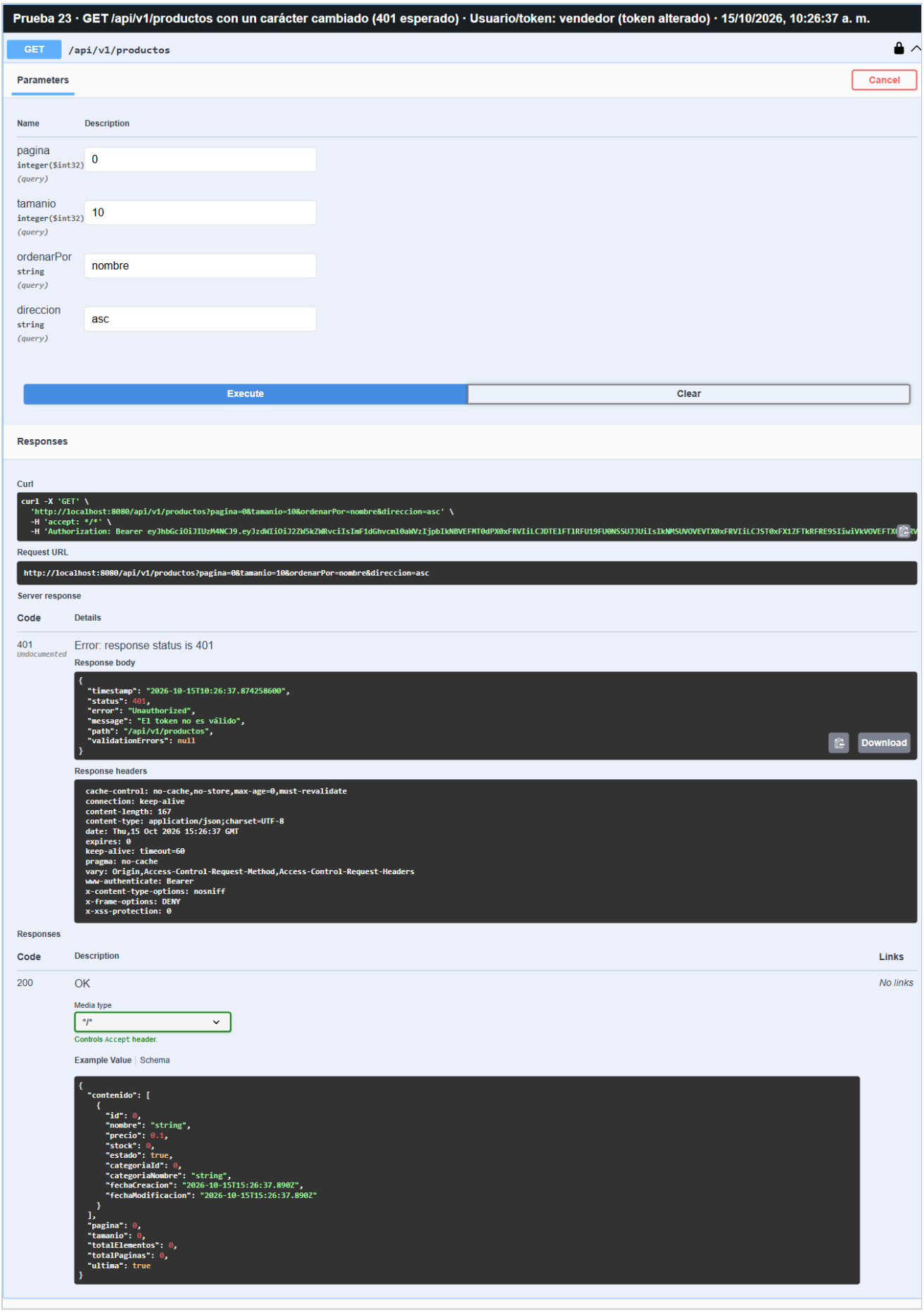
Prueba 22 · Alta con rollds [2, 99]

Usuario / token: admin · **Esperado:** 404 «Roles no encontrados: [99]» · **Obtenido:** 404



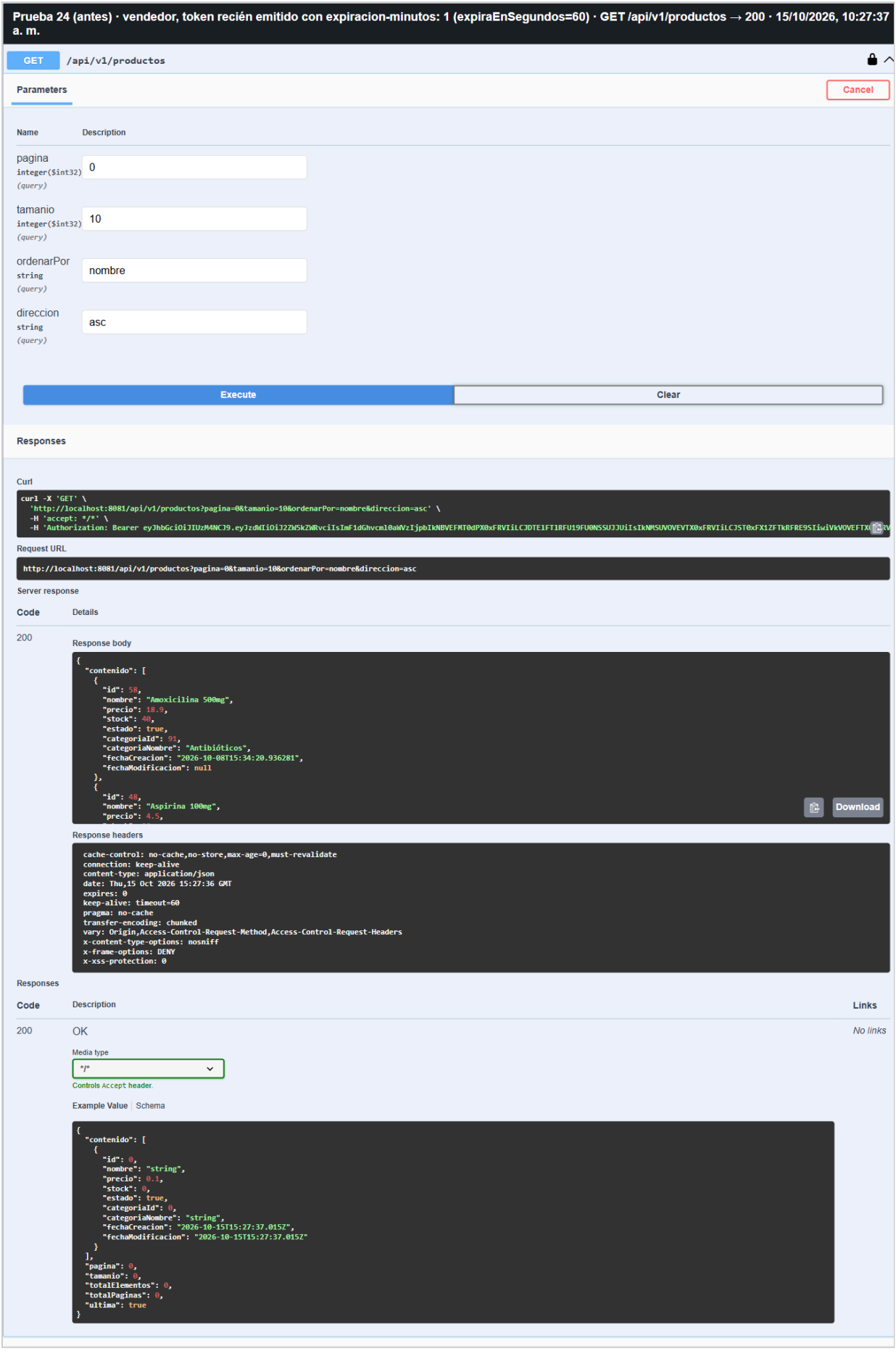
Prueba 23 · Token con un carácter cambiado

Usuario / token: vendedor · **Esperado:** 401 «El token no es válido» · **Obtenido:** 401



Prueba 24 · Token con expiracion-minutos: 1, 2 minutos después

Usuario / token: vendedor · **Esperado:** 401 «El token ha expirado. Inicie sesión nuevamente» · **Obtenido:** 401



Prueba 24 · vendedor, mismo token 2 minutos después · GET /api/v1/productos (401 esperado) · 15/10/2026, 10:29:42 a. m.

GET /api/v1/productos

Parameters — Cancel

Name	Description
pagina integer($int32) (query)	0
tamanio integer($int32) (query)	10
ordenarPor string (query)	nombre
direccion string (query)	asc

Execute | Clear

Responses

Curl

```
curl -X 'GET' \
  'http://localhost:8081/api/v1/productos?pagina=0&tamanio=10&ordenarPor=nombre&direccion=asc' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTE1FT1RFU19FU0NSSUJJUiIsIkNMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX
```

Request URL

```
http://localhost:8081/api/v1/productos?pagina=0&tamanio=10&ordenarPor=nombre&direccion=asc
```

Server response

Code	Details
401 *Undocumented*	Error: response status is 401

Response body

```
{
  "timestamp": "2026-10-15T10:29:42.853835300",
  "status": 401,
  "error": "Unauthorized",
  "message": "El token ha expirado. Inicie sesión nuevamente",
  "path": "/api/v1/productos",
  "validationErrors": null
}
```

Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-length: 192
content-type: application/json;charset=UTF-8
date: Thu,15 Oct 2026 15:29:42 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
www-authenticate: Bearer
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

Code	Description	Links
200	OK Media type: */* Controls Accept header. Example Value | Schema	*No links*

```
{
  "contenido": [
    {
      "id": 0,
      "nombre": "string",
      "precio": 0.1,
      "stock": 0,
      "estado": true,
      "categoriaId": 0,
      "categoriaNombre": "string",
      "fechaCreacion": "2026-10-15T15:29:42.868Z",
      "fechaModificacion": "2026-10-15T15:29:42.868Z"
    }
  ],
  "pagina": 0,
  "tamanio": 0,
  "totalElementos": 0,
  "totalPaginas": 0,
  "ultima": true
}
```